Cybersecurity Scenario-Based Question Bank

How students should answer

For every scenario, students should avoid jumping directly to a tool or attack.

A strong answer should generally follow:

1. Understand the situation
   ↓
2. Identify what is known
   ↓
3. Identify what is unknown
   ↓
4. Collect evidence
   ↓
5. Analyze the evidence
   ↓
6. Form a hypothesis
   ↓
7. Validate the hypothesis
   ↓
8. Assess impact
   ↓
9. Contain / remediate
   ↓
10. Prevent recurrence

MODULE 1 — NETWORKING SCENARIOS

Scenario 1 — "The Website Is Not Opening"

Situation

A user reports:

"I can access Google, but I cannot access our company's internal application."

Other users can access the application.

Questions

1. What could be wrong?
2. What would you check first?
3. Would you start with the browser?
4. How would you determine whether DNS is working?
5. How would you determine whether the server is reachable?
6. How would you check the routing path?
7. How would you determine whether the port is accessible?
8. What commands would you use?
9. What would you inspect with Wireshark?
10. How would you distinguish between:

- DNS failure
- routing failure
- firewall blocking
- application failure

- server failure?

11. What evidence would confirm each possibility?

Practical task

Give the student a deliberately misconfigured VM.
They must identify the problem without being told what was changed.

Scenario 2 — DNS Failure

Situation

A company's internal application suddenly becomes inaccessible using:
portal.company.local
But accessing it using its IP address works.

Questions

1. What does this immediately suggest?
2. What DNS query would you perform?
3. What should the expected DNS response contain?
4. How would you determine whether the DNS server is reachable?
5. What DNS record would you investigate?
6. Could DNS caching be involved?
7. How would you identify whether the problem is client-side or server-side?
8. What logs could help?
9. Could this be malicious?
10. What security attacks involving DNS should you know about?

Scenario 3 — ARP Spoofing

Situation

Users on a local network report intermittent connectivity problems.
A network administrator notices that multiple machines appear to associate the gateway IP with different MAC addresses.

Questions

1. What protocol is involved?
2. What could cause this?
3. What is ARP spoofing?
4. How could an attacker abuse it?
5. How could this enable MITM?
6. What evidence would you collect?
7. How would you verify whether spoofing is actually occurring?
8. What would you look for in Wireshark?
9. How could defenders mitigate the problem?
10. What would you do if this were a real corporate incident?

Scenario 4 — Unexpected Open Port

Situation

A Linux server is supposed to host only a web application.
A security assessment discovers:
22/tcp
80/tcp
443/tcp
3306/tcp

Questions

1. What concerns you?
2. What does port 3306 usually indicate?
3. Does an open port automatically mean a vulnerability?
4. What would you investigate next?
5. Which process owns the port?
6. Is the database supposed to be externally accessible?
7. How would you determine who can reach it?
8. What firewall controls could be applied?
9. What logs should be monitored?
10. How would you document this finding?

Scenario 5 — Possible Port Scan

Situation

A server administrator notices hundreds of connection attempts against different ports within a short period.

Questions

1. What might be happening?
2. What evidence would you collect?
3. What source generated the connections?
4. Which ports were targeted?
5. What was the frequency?
6. Was the scan successful?
7. How would you distinguish scanning from legitimate activity?
8. Which tools could help?
9. How could the activity be detected automatically?
10. What defensive controls could reduce exposure?

MODULE 2 — LINUX SCENARIOS

Scenario 6 — 100% CPU Usage

Situation

A production Linux server suddenly reaches:
CPU: 100%
The application becomes slow.

Questions

1. What do you check first?
2. Which process is consuming CPU?
3. Which user owns that process?
4. When did the process start?
5. What parent process created it?
6. Is it a legitimate service?
7. What network connections does it have?
8. What logs should you inspect?
9. Could this be a security incident?
10. Would you immediately kill the process?
11. How would you preserve evidence?
12. How would you prevent recurrence?

Practical task

Give students a VM containing a deliberately misbehaving process.
They must investigate it using Linux tools.

Scenario 7 — Suspicious Linux Process

Situation

A process named:
update-service
is running as root.
The administrator doesn't recognize it.

Questions

1. What would you investigate?
2. Where is the executable located?
3. What user started it?
4. What is its parent process?
5. When was the file created?
6. What network connections does it make?
7. Is there a corresponding service?
8. Is there a cron job?
9. What logs mention the process?
10. How would you determine whether it is malicious or legitimate?

Scenario 8 — SSH Brute Force

Situation

A Linux server's authentication logs contain thousands of failed SSH login attempts.

Questions

1. What does this indicate?
2. How would you identify the source IPs?
3. Are all attempts targeting the same account?
4. Were any attempts successful?
5. What time period was involved?
6. What evidence would you preserve?
7. How would you investigate a successful login?
8. What controls could reduce the risk?
9. Would simply changing the SSH port be sufficient?
10. What monitoring/detection would you implement?

Scenario 9 — Permission Problem

Situation

A developer says:

"The application cannot read its configuration file."

You find:

-rw------- 1 root root config.env

The application runs as:

appuser

Questions

1. Why can't the application read the file?
2. What permissions currently exist?
3. What are the risks of simply running the application as root?
4. How would you fix the problem using least privilege?
5. Should the file be readable by everyone?
6. Could the configuration contain secrets?
7. How should secrets ideally be handled?

MODULE 3 – WINDOWS SCENARIOS

Scenario 10 – Suspicious Login

Situation

A Windows workstation shows:
23 failed login attempts
↓
successful login
↓
privileged activity

Questions

1. Why is this suspicious?
2. Which logs would you inspect?
3. What information should you extract?
4. What account was targeted?
5. What was the source?
6. What happened after successful authentication?
7. Could this be a legitimate user?
8. What additional evidence would you collect?
9. What containment actions might be appropriate?
10. How could this behavior be detected automatically?

Scenario 11 – Suspicious PowerShell

Situation

A SOC alert reports unusual PowerShell execution on an employee workstation.

Questions

1. Why can PowerShell activity be security-relevant?
2. What process launched PowerShell?
3. Which user executed it?
4. When did it execute?
5. What command or script was involved?
6. What network connections followed?
7. What parent-child process relationship would you investigate?
8. What logs would you correlate?
9. How would you determine whether it was legitimate?
10. What containment would be appropriate if malicious activity were confirmed?

Scenario 12 – New Administrator Account

Situation

A new account suddenly appears in the local Administrators group.
The system owner says:
"I didn't create this account."

Questions

1. Why is this important?
2. What logs would you inspect?
3. When was the account created?
4. Who created it?
5. What machine was involved?
6. What other activity occurred around that time?
7. Was the account used?
8. What permissions does it have?
9. What would you do if compromise were suspected?
10. How would you detect similar activity in the future?

MODULE 4 – ACTIVE DIRECTORY

Scenario 13 – Domain Account Compromise

Situation

A domain account normally used from Delhi suddenly authenticates from another unusual location/device. Shortly afterward, the account accesses several internal resources.

Questions

1. What could this indicate?
2. What authentication evidence would you collect?
3. What machines did the account access?
4. What resources did it access?
5. Was the account privileged?
6. What authentication protocol was involved?
7. What other accounts show similar activity?
8. How would you determine whether credentials were compromised?
9. What containment actions are possible?
10. How would you prevent similar incidents?

Scenario 14 — Excessive Privileges

Situation

A junior employee belongs to:
Domain Users
Developers
Backup Operators
Administrators

Questions

1. What security principle is violated?
2. What is least privilege?
3. Why is unnecessary administrator access dangerous?
4. What could an attacker gain if the account were compromised?
5. Which permissions are actually required?
6. How would you redesign the access?
7. How would you audit similar accounts?
8. What controls should prevent privilege accumulation?

Scenario 15 — Suspicious Lateral Movement

Situation

A workstation is compromised.
Within several minutes, the same user account authenticates to five other machines.

Questions

1. What might this indicate?
2. What is lateral movement?
3. What evidence should be collected?
4. Which systems were accessed?
5. What authentication occurred?
6. Was the account privileged?
7. What happened on the destination machines?
8. How would you determine the original compromised machine?
9. How would you contain the incident?
10. How could segmentation and privilege management reduce the impact?

MODULE 5 — WEB SECURITY

Scenario 16 — IDOR / Broken Authorization

Situation

A web application contains:
GET /api/orders/1001
A user authenticated as User A changes it to:
GET /api/orders/1002
and receives User B's order.

Questions

1. What security issue might exist?
2. Is authentication working?
3. Why is authentication not enough?
4. What authorization check is missing?
5. What is the impact?
6. How would you reproduce the issue safely?
7. How would you verify the vulnerability?
8. How should the backend fix it?
9. How would you test the fix?
10. How would you report it professionally?

Scenario 17 — SQL Injection

Situation

A login application constructs a database query using user input.
The application behaves unexpectedly when specially crafted input is supplied.

Questions

1. What vulnerability might exist?
2. Why does it happen?
3. What evidence would you collect?
4. How would you validate the issue in a controlled lab?
5. What could an attacker potentially access?
6. What is the safest remediation?
7. Why is string escaping alone not the preferred solution?
8. How can WAF/logging/detection help?
9. How would you retest the application?

Scenario 18 — Stored XSS

Situation

A comment submitted by one user executes browser-side script whenever another user views the comment.

Questions

1. What type of vulnerability is this?
2. Why is it stored?
3. Where is the malicious content stored?
4. Who is affected?
5. What is the potential impact?
6. What is output encoding?
7. What is Content Security Policy?
8. What application-layer fixes should be considered?
9. How would you test the fix?

Scenario 19 — File Upload

Situation

A profile page allows users to upload profile pictures.
The application accepts arbitrary file types.

Questions

1. What security concerns exist?
2. Why is checking only the filename extension insufficient?
3. What could happen if executable content were uploaded?
4. Where should uploaded files be stored?
5. Should the upload directory allow execution?
6. What validation should occur?
7. What size limits should exist?
8. How should files be renamed?
9. What should be logged?
10. How would you test the controls?

Scenario 20 — Path Traversal

Situation

An application provides:
GET /download?file=report.pdf
A tester discovers that manipulating the file parameter accesses files outside the intended directory.

Questions

1. What vulnerability might exist?
2. Why does it happen?
3. What is the security boundary being bypassed?
4. What information could potentially be exposed?
5. How would you validate it safely?
6. How should the application prevent it?
7. Why is simple string replacement unreliable?
8. How should the application handle file identifiers?

MODULE 6 – BURP SUITE / WEB TESTING

Scenario 21 – Authentication Bypass Investigation

Situation

You have two accounts:
userA
userB
The application has login and profile APIs.

Task

Using a controlled lab:

1. Authenticate as User A.
2. Observe the requests.
3. Identify session information.
4. Identify resource identifiers.
5. Determine whether authorization is enforced server-side.
6. Document your observations.
7. Explain the security implications.

Questions

- Which part of the request did you inspect?
- What makes you believe authorization is or isn't enforced?
- Why shouldn't the client be trusted to enforce authorization?

MODULE 7 – VAPT SCENARIOS

Scenario 22 – You Have 24 Hours

Situation

A company authorizes you to assess:
3 web servers
1 API
1 internal application
You have only 24 hours.

Questions

1. What do you do first?
2. How do you define scope?
3. What information do you collect?
4. How do you prioritize targets?
5. What would you scan?
6. What would you manually test?
7. How do you avoid unnecessary disruption?
8. How do you validate findings?
9. How do you prioritize vulnerabilities?
10. What should the final report contain?

Scenario 23 — False Positive

Situation

A scanner reports:
"Critical vulnerability detected."
Manual testing doesn't reproduce the issue.

Questions

1. What is a false positive?
2. Why might scanners produce false positives?
3. Should you immediately report it as critical?
4. How would you validate it?
5. What evidence should you collect?
6. How would you communicate the result?

Scenario 24 — Critical Vulnerability in Production

Situation

During an authorized assessment, you discover a critical vulnerability in a production system.
You believe exploitation could disrupt the service.

Questions

1. Should you continue testing?
2. What does the rules of engagement say?
3. Who should be informed?
4. What evidence can safely be collected?
5. Should you attempt destructive exploitation?
6. How should the finding be documented?
7. What should remediation include?
8. How should retesting be performed?

This tests whether students understand that:
Being technically capable of exploiting something does not mean you are authorized to exploit it.

MODULE 8 — SOC / BLUE TEAM

Scenario 25 — Brute Force Investigation

Situation SIEM generates:
"Multiple authentication failures detected."

Questions

1. What do you investigate first?
2. Which account?
3. Which source?
4. How many failures?
5. Over what period?
6. Was there a successful login?
7. Were other accounts targeted?
8. Is the source internal or external?
9. What additional logs should be correlated?
10. Is this an incident?
11. What severity would you assign?
12. What containment could be considered?

Scenario 26 — Malware-Like Behavior

Situation

A workstation starts:

Unknown process

↓

Creates files

↓

Makes outbound connections

↓

Creates persistence

Questions

1. What would you investigate?
2. What process started it?
3. Which user owns it?
4. Where is the executable?
5. What files were created?
6. What network destinations were contacted?
7. What persistence mechanism was created?
8. What logs support your conclusion?
9. How would you contain the machine?
10. What evidence should be preserved?
11. How would you determine scope?

Scenario 27 — Data Exfiltration

Situation

A workstation normally uploads approximately:

50 MB/day

Today it uploads:

8 GB

to an unfamiliar external destination.

Questions

1. Why is this suspicious?
2. What data may have been transferred?
3. Which process generated the traffic?
4. Which destination received it?
5. What protocol was used?
6. What DNS activity occurred?
7. What files were accessed before the transfer?
8. Which user was logged in?
9. How would you contain the system?
10. How would you investigate whether sensitive information was exposed?

Scenario 28 — Impossible Travel

Situation

A user authenticates from:
Delhi — 10:00
and:
London — 10:15

Questions

1. Why might this trigger an alert?
2. Does this prove account compromise?
3. What could cause a false positive?
4. What additional evidence would you collect?
5. What device information would you inspect?
6. What authentication method was used?
7. Were there other suspicious activities?
8. How would you respond?

Scenario 29 — Privileged Account Activity

Situation

A domain administrator account is used at 3:00 AM to access multiple servers.
The administrator normally works during business hours.

Questions

1. Why is this suspicious?
2. What evidence would you collect?
3. Which servers were accessed?
4. What actions occurred?
5. Were changes made?
6. Was MFA used?
7. Was the source device expected?
8. Could it be legitimate maintenance?
9. How would you determine the answer?
10. What containment would be appropriate if unauthorized?

MODULE 9 — INCIDENT RESPONSE

Scenario 30 — "Your Server Has Been Compromised"

Situation

A security team tells you:

"We believe one of our Linux servers has been compromised."

You are the first person investigating.

Questions

1. What do you do first?
2. What should you avoid doing?
3. How do you preserve evidence?
4. What volatile information might be useful?
5. What processes are running?
6. What network connections exist?
7. Which users are logged in?
8. What authentication events occurred?
9. What files changed recently?
10. What persistence mechanisms would you inspect?
11. How do you determine initial access?
12. How do you determine whether other machines are affected?
13. How do you contain the system?
14. How do you eradicate the threat?
15. How do you recover?
16. What lessons should be documented?

MODULE 10 — INTEGRATED RED TEAM + BLUE TEAM SCENARIOS

These should be the **highest level of the semester**.

Scenario 31 — Full Attack Chain

Environment

Internet
↓
Web Server
↓
Application Server
↓
Database
↓
Internal Network
↓
Windows Domain

Situation

A web application has been compromised.

The SOC sees:

Web request anomaly
↓
New process
↓

Outbound connection

↓

Internal authentication

↓

Multiple Windows systems accessed

Student tasks

Phase 1 — Reconnaissance

Determine:

- Hosts
- Services
- Attack surface

Phase 2 — Web Analysis

Determine:

- Suspicious requests
- Application weakness
- Initial access hypothesis

Phase 3 — Host Investigation

Determine:

- Process
- User
- Files
- Network connections
- Persistence

Phase 4 — Lateral Movement Analysis

Determine:

- Accounts used
- Destination systems
- Authentication events

Phase 5 — Detection

Determine:

- Which logs detected the activity?
- Which activity was missed?

Phase 6 — Response

Recommend:

- Containment
- Eradication
- Recovery

Phase 7 — Prevention

Recommend:

- Application fixes
- Network controls
- Identity controls
- Monitoring improvements

Scenario 32 — The "Everything Looks Normal" Incident

Situation

No antivirus alert exists.
No obvious malware is found.
However:
DNS traffic increased
Authentication anomalies increased
Outbound traffic increased

Questions

1. Would you dismiss the incident?
2. Why or why not?
3. What hypotheses could explain the behavior?
4. What telemetry would you correlate?
5. Which machines should be investigated?
6. Which users should be investigated?
7. What baseline would you compare against?
8. How would you determine whether this is malicious?
9. What would make the evidence stronger?

This tests whether students understand that:

Security analysis is not simply waiting for an antivirus alert.

MODULE 11 — CLOUD SECURITY SCENARIOS

Scenario 33 — Public Storage

Situation

A cloud storage bucket containing company documents is accidentally configured for public access.

Questions

1. What is the security issue?
2. What is the potential impact?
3. How would you determine whether anyone accessed the data?
4. Which logs would you inspect?
5. How would you contain the issue?
6. How would you correct permissions?
7. How would you prevent recurrence?
8. What principle of security was violated?

Scenario 34 — Excessive Cloud IAM

Situation

A developer's cloud identity has:
Full administrator access
but only needs to deploy one application.

Questions

1. What is wrong?
2. What principle applies?
3. What could happen if the account is compromised?
4. How would you redesign permissions?
5. How would you audit existing identities?
6. How should privileged access be monitored?

MODULE 12 — TROUBLESHOOTING SCENARIOS

These are extremely important because real security work often begins with:
"Something unusual is happening. Find out why."

Scenario 35 — Server Is Slow

Students receive:
CPU: 92%
Memory: 94%
Network: normal
Disk: normal
They must determine the root cause.

Scenario 36 — Application Is Slow

Students receive:
Application latency ↑
Network latency normal
CPU normal
Database latency ↑
Questions:

- What subsystem is likely involved?
- What metrics would you inspect?
- How would you confirm it?
- Is this necessarily a security problem?

Scenario 37 — Network Is Slow

Students receive:

Packet loss: 8%

Latency: high

DNS: normal

Server CPU: normal

Determine:

- Where the problem might exist.
- What evidence should be collected.
- What tools can isolate the problem.

MODULE 13 — SECURITY DECISION-MAKING

These questions test judgment rather than memorization.

Scenario 38 — "Block the IP"

Situation

A SOC analyst sees suspicious traffic from:

203.x.x.x

They immediately want to block the IP.

Questions

1. Is blocking always the correct first action?
2. What evidence should be collected?
3. Could the IP be shared infrastructure?
4. Could it be a legitimate service?
5. What additional indicators should be investigated?
6. When would blocking be appropriate?
7. What are the risks of blocking incorrectly?

Scenario 39 — "Patch Everything Immediately"

Situation

A vulnerability scanner reports 500 vulnerabilities.

Questions

1. Should all 500 be patched immediately?
2. How should vulnerabilities be prioritized?
3. What factors determine risk?
4. What is asset criticality?
5. What is exploitability?
6. What is exposure?
7. What compensating controls could exist?
8. Why is vulnerability severity alone insufficient?

Scenario 40 – "The Scanner Says It's Safe"

Situation

An automated scanner reports:

"No critical vulnerabilities detected."

Questions

1. Does that mean the application is secure?
2. What can automated scanners miss?
3. Why is manual testing important?
4. How would you test authorization?
5. How would you test business logic?
6. How would you test authentication?
7. What types of vulnerabilities are difficult to detect automatically?

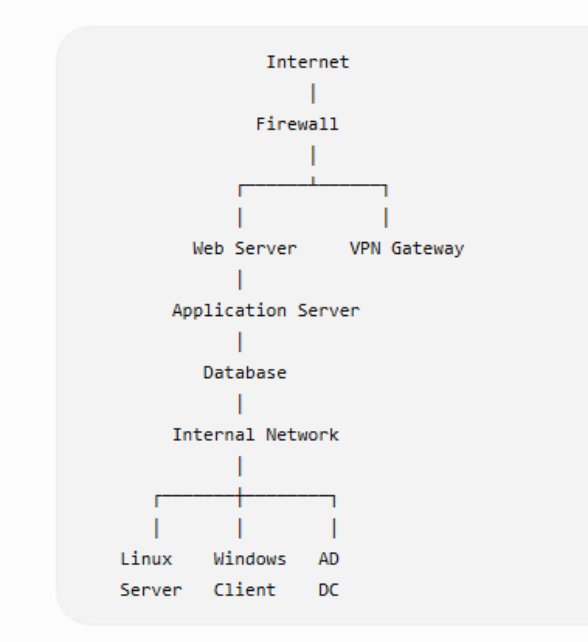
MODULE 14 – FINAL CAPSTONE SCENARIO

This should be the **final scenario-based examination**.

Scenario 41 – Cybersecurity Investigation Challenge

Environment

Students receive:



They are given:

- Network diagram
- IP addresses
- Nmap results
- Wireshark capture
- Linux logs
- Windows logs
- Web server logs
- Application logs
- Authentication events

Situation

The company reports:

"A customer account was accessed unexpectedly, and several internal systems show unusual activity."
The student must determine:

Phase 1 — Understand

1. What systems exist?
2. What services exist?
3. Which assets are important?

Phase 2 — Reconnaissance

4. What is exposed?
5. What services are unexpected?
6. What attack surface exists?

Phase 3 — Web Investigation

7. Were suspicious requests made?
8. Was authentication bypassed?
9. Was authorization bypassed?
10. Was there suspicious input?

Phase 4 — Network Investigation

11. What hosts communicated?
12. What external destinations were contacted?
13. What DNS queries occurred?
14. What unusual connections exist?

Phase 5 — Host Investigation

15. Which processes were running?
16. Which users executed them?
17. Were files modified?
18. Was persistence created?

Phase 6 — Identity Investigation

19. Were suspicious logins observed?
20. Were privileged accounts involved?
21. Was lateral movement attempted?

Phase 7 — Timeline

Construct:
T1 → Initial activity
T2 → Initial access
T3 → Execution
T4 → Persistence
T5 → Credential/identity activity
T6 → Lateral movement
T7 → Data access
T8 → Detection

Phase 8 — Risk Assessment

Determine:

- Affected assets
- Confidentiality impact
- Integrity impact
- Availability impact
- Severity

- Scope

Phase 9 – Response

Recommend:

Containment

↓

Evidence preservation

↓

Eradication

↓

Recovery

↓

Monitoring

Phase 10 – Prevention

Recommend improvements across:

Application

Network

Identity

Host

Logging

Monitoring

Access control

Security process
